

Seals MES System

系统管理员管理 第三方接口手册

API 密钥管理 · 权限配置 · 安全策略 · 日志审计

文档版本：V1.0

适用对象：MES 系统管理员

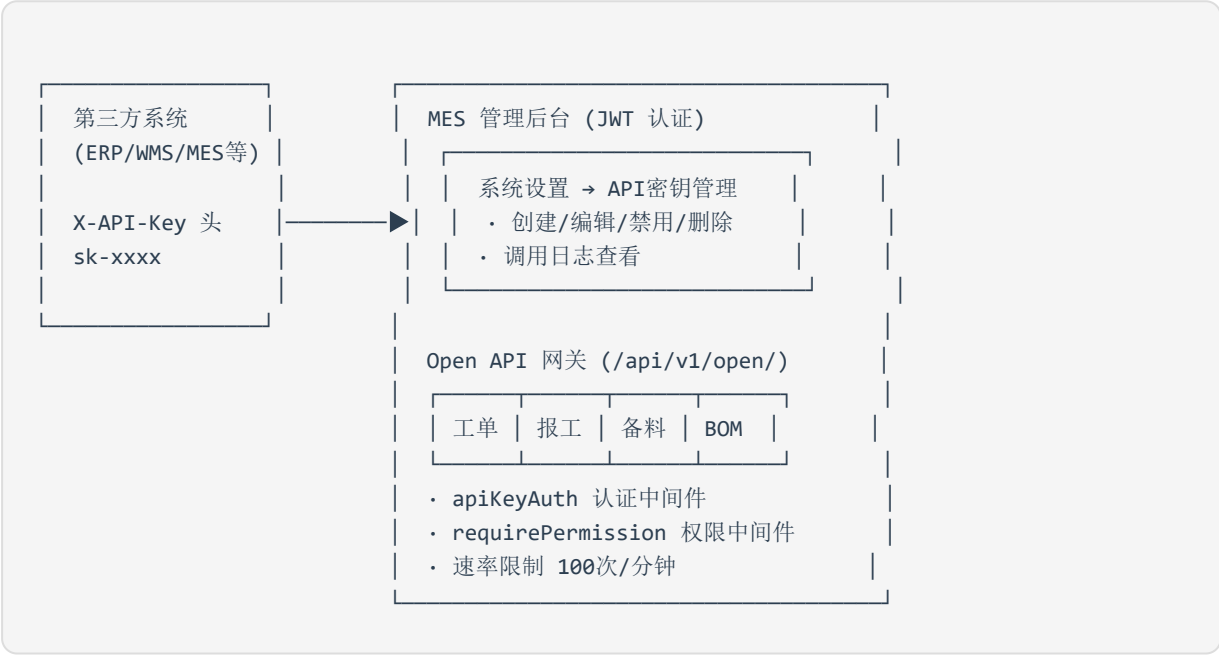
编制日期：2026年5月

第一章 概述

1.1 手册目的

本手册面向 MES 系统管理员，详细说明如何管理第三方系统接入 MES 的 Open API 接口，包括：API 密钥的创建与维护、权限分配策略、安全防护配置、调用日志审计等全部管理操作。

1.2 系统架构概览



1.3 认证方式对比

对比项	JWT Token（内部用户）	API Key（第三方对接）
认证方式	账号密码登录获取 Token	静态密钥 <code>sk-xxxx</code>
有效期	短期（2小时 + 自动刷新）	长期（可设置过期时间或永不过期）
传输方式	<code>Authorization: Bearer xxx</code>	<code>X-API-Key: sk-xxx</code>
权限范围	基于角色的完整系统权限	4模块 × 读写 = 8个独立权限位
适用场景	用户通过浏览器访问	服务间自动化调用

第二章 API 密钥管理

2.1 进入管理页面

- 1 以管理员账号登录 MES 系统后台
- 2 在左侧导航栏点击 **系统设置** 展开子菜单
- 3 点击 **API密钥管理** 进入管理页面

页面路由： `/api-keys` ， 权限代码： `system` ， 仅管理员可见。

2.2 创建 API 密钥

2.2.1 操作步骤

- 1 点击页面右上角 **新建密钥** 按钮
- 2 在弹窗中填写密钥信息（详见下方字段说明）
- 3 点击 **确定** 提交
- 4 系统弹出密钥值， **立即复制并妥善保管**
- 5 点击 **我已复制保管** 关闭窗口

危险 密钥创建成功后仅此一次展示完整值，关闭窗口后无法再次查看完整密钥！若密钥遗失，只能通过"重新生成"功能获取新密钥。

2.2.2 字段说明

字段	必填	说明	示例
密钥名称	必填	标识密钥用途	ERP系统对接
客户端名称	必填	第三方系统/公司名称	XX科技有限公司
描述	选填	补充说明用途	用于ERP同步生产工单数据
访问权限	—	4个模块各勾选读/写	见下方权限配置
频率限制	—	每分钟最大请求数，默认100	100

IP白名单	选填	逗号分隔的IP列表，留空不限制	192.168.1.100,10.0.0.5
过期时间	选填	留空=永不过期	2027-12-31 23:59:59

2.2.3 权限勾选说明

创建弹窗中的"访问权限"区域以 2×2 网格展示 4 个模块，每个模块有"读取"和"写入"两个复选框：

模块	读取权限	写入权限	默认
生产工单	可查询工单列表和详情	可创建和更新工单	读取=勾选，写入=不勾选
工序报工	可查询报工列表和详情	可创建报工记录	读取=勾选，写入=不勾选
按工序备料	可查询备料单和明细	可按工序生成备料单	读取=勾选，写入=不勾选
设计BOM	可查询BOM列表/详情/树/扁平	(预留，暂未开放写入)	读取=勾选，写入=不勾选

提示 建议遵循最小权限原则：仅为第三方分配其业务场景必需的权限。例如只读对接只需勾选"读取"，不需要勾选"写入"。

2.3 查看密钥列表

管理页面以表格展示所有已创建的 API 密钥，包含以下列：

列名	说明
密钥名称	创建时填写的标识名
客户端	第三方系统/公司名称
密钥	脱敏显示，如 sk-a4****1c9
权限	以标签显示各模块权限，如 工单读写 报工读
状态	启用 或 禁用
过期时间	永不过期 / 日期（已过期显示红色）
频率限制	次/分钟
最近使用	最后调用时间，从未使用显示灰色

2.4 编辑密钥

1. 在密钥列表中点击某行的 **编辑** 按钮
2. 在弹窗中修改权限、频率限制、IP白名单、过期时间、状态等
3. 点击 **确定** 保存

说明 编辑操作不会改变密钥值，仅修改权限和配置参数。

2.5 禁用/启用密钥

在密钥列表的操作列，点击 **更多** → **禁用** 或 **更多** → **启用**。

- 禁用后，使用该密钥的所有 API 请求将返回 **401 Unauthorized**
- 启用后，密钥恢复可用
- 禁用是临时操作，密钥数据不会丢失

提示 当发现密钥可能泄露时，应第一时间禁用密钥，再排查问题后决定是重新启用还是重新生成。

2.6 重新生成密钥

1. 在密钥列表中点击 **更多** → **重新生成**
2. 系统弹出确认框："重新生成后旧密钥将立即失效，确定继续？"
3. 点击确定后，系统生成新的密钥值
4. **立即复制新密钥并通知第三方更新配置**

警告 重新生成后旧密钥立即失效，使用旧密钥的所有请求将返回 401 错误。请务必先协调第三方做好切换准备。

2.7 删除密钥

1. 在密钥列表中点击 **更多** → **删除**
2. 系统弹出确认框："确定删除此密钥？删除后不可恢复"
3. 点击确定后，密钥被永久删除

危险 删除操作不可逆，密钥及关联的所有调用日志将无法恢复。如只是临时停用，请使用"禁用"而非"删除"。

第三章 查看调用日志

3.1 打开日志窗口

在密钥列表中点击某行的 **日志** 按钮，弹出该密钥的调用日志窗口。

3.2 日志字段说明

字段	说明
时间	API调用的确切时间
端点	请求的API路径，如 <code>/api/v1/open/orders</code>
方法	HTTP方法：GET / POST / PUT
状态码	响应状态码： 200 成功， 4xx/5xx 失败
响应时间	服务端处理耗时（毫秒）
IP地址	请求来源IP

3.3 日志分析要点

观察现象	可能原因	处理建议
大量 401 状态码	密钥过期或被禁用	检查密钥有效期和状态
大量 403 状态码	权限不足	检查该密钥的权限配置
大量 429 状态码	请求频率超限	适当提高频率限制值
来源IP异常	密钥可能泄露	立即禁用密钥，配置IP白名单
响应时间突然变长	数据库或网络异常	检查服务器性能
非工作时间段有调用	异常自动化任务或泄露	核实第三方调用计划

第四章 安全策略配置

4.1 速率限制

4.1.1 默认限制

Open API 网关默认速率限制为 **100次/分钟**，超出后返回 HTTP 429 状态码。

4.1.2 自定义限制

在创建或编辑密钥时，可修改"频率限制"字段：

业务场景	建议值
低频查询（每日同步几次）	20~50 次/分钟
常规数据同步	100 次/分钟（默认）
高频批量读取	200~500 次/分钟
实时推送对接	500~1000 次/分钟

警告 过高的频率限制可能影响系统整体性能，建议根据实际需要设置合理值。

4.2 IP 白名单

4.2.1 配置方法

在创建或编辑密钥时，在"IP白名单"字段中填写允许访问的 IP 地址，多个 IP 用英文逗号分隔。

4.2.2 配置示例

```
# 单个IP
192.168.1.100

# 多个IP
192.168.1.100,10.0.0.5,172.16.0.1

# 不限制（留空即可）
```

4.2.3 注意事项

- 留空表示不限制来源IP，任何IP都可以使用该密钥
- 配置后，仅列表中的IP可以访问，其他IP将返回 `403 Forbidden`
- 如果第三方服务器有多个出口IP，需全部列出
- 注意区分内网IP和外网IP

4.3 密钥过期策略

4.3.1 配置方法

在创建或编辑密钥时，设置"过期时间"。留空表示永不过期。

4.3.2 建议策略

密钥类型	建议有效期	说明
临时对接测试	7~30天	测试完成后自动失效
正式对接	1年	定期轮换，配合重新生成
长期合作伙伴	2~3年	配合IP白名单使用

4.4 安全最佳实践

1. **最小权限原则**：仅为第三方分配必需的模块权限
2. **必须配置IP白名单**：生产环境强烈建议配置IP白名单
3. **设置过期时间**：避免永久密钥，定期轮换
4. **密钥泄露应急流程**：
 1. 立即禁用密钥
 2. 通知第三方停止使用
 3. 重新生成密钥
 4. 通过安全渠道将新密钥传递给第三方
5. **定期审计**：每月检查一次调用日志，关注异常模式
6. **生产环境HTTPS**：确保API通过HTTPS访问，防止密钥被嗅探

第五章 权限配置参考

5.1 权限矩阵总览

权限位	数据库字段	对应接口	允许的操作
工单-读	perm_order_read	GET /open/orders GET /open/orders/:id	查询工单列表、查询工单详情
工单-写	perm_order_write	POST /open/orders PUT /open/orders/:id	创建工单、更新工单
报工-读	perm_work_report_read	GET /open/work-reports GET /open/work-reports/:id	查询报工列表、查询报工详情
报工-写	perm_work_report_write	POST /open/work-reports	创建报工记录
备料-读	perm_prep_read	GET /open/material-preparations GET /open/material-preparations/:id/details GET /open/material-preparations/:id/details-grouped	查询备料单列表、查询备料明细、按工序分组查询
备料-写	perm_prep_write	POST /open/material-preparations/generate-by-process	按工序自动生成备料单
BOM-读	perm_bom_read	GET /open/bom GET /open/bom/:id GET /open/bom/:id/tree GET /open/bom/:id/flatten	查询BOM列表、详情、树形结构、扁平化展开
BOM-写	perm_bom_write	—	预留，暂未开放

5.2 典型场景配置

场景一：ERP 同步生产工单（只读）

权限	设置
工单-读	☒

工单-写	不勾选
报工-读	勾选
报工-写	不勾选
备料-读	不勾选
备料-写	不勾选
BOM-读	不勾选
BOM-写	不勾选

场景二：WMS 同步备料与报工数据

权限	设置
工单-读	勾选
工单-写	不勾选
报工-读	勾选
报工-写	勾选
备料-读	勾选
备料-写	勾选
BOM-读	不勾选
BOM-写	不勾选

场景三：产品数据管理系统同步BOM

权限	设置
工单-读	不勾选
工单-写	不勾选
报工-读	不勾选
报工-写	不勾选
备料-读	不勾选
备料-写	不勾选

BOM-读	勾选
BOM-写	不勾选

第六章 常见问题处理

6.1 第三方反馈"401 Unauthorized"

可能原因及排查步骤：

1. 密钥未在请求头 `X-API-Key` 中传递 → 检查第三方请求代码
2. 密钥拼写错误 → 检查密钥值是否完整（包括 `sk-` 前缀）
3. 密钥已过期 → 在管理页面检查过期时间
4. 密钥已被禁用 → 在管理页面检查启用状态
5. 密钥已被重新生成 → 确认第三方使用的是最新密钥

6.2 第三方反馈"403 Forbidden"

可能原因及排查步骤：

1. 权限不足 → 检查密钥是否勾选了对应模块的读/写权限
2. IP不在白名单 → 检查密钥的IP白名单配置，确认第三方出口IP

6.3 第三方反馈"429 Too Many Requests"

1. 请求频率超限 → 查看密钥的频率限制设置，根据需要调高
2. 如果是短时间突发 → 建议第三方实现请求队列和退避重试

6.4 需要变更密钥权限

1. 在密钥列表中点击 **编辑**
2. 重新勾选/取消勾选对应模块的权限
3. 权限变更立即生效，无需重新生成密钥

6.5 密钥泄露紧急处理

1. 立即在管理页面点击 **更多** → **禁用**
2. 通知第三方停止使用该密钥
3. 评估影响范围（查看调用日志中是否有异常IP）
4. 确认安全后，点击 **更多** → **重新生成**

5. 将新密钥通过安全渠道传递给第三方

6.6 管理操作速查表

需求	操作	密钥值变化	第三方需更新
修改权限	编辑 → 勾选/取消权限	不变	否
调整频率限制	编辑 → 修改频率限制	不变	否
添加IP白名单	编辑 → 填写IP	不变	否
临时停用	更多 → 禁用	不变	否（恢复启用即可）
密钥泄露	更多 → 重新生成	变化	是（必须更新）
永久移除	更多 → 删除	删除	是（需重新创建）